

ASR exception register — P4

Owner: IT (M. I. Akmal) · **Applies to:** Defender Attack Surface Reduction rules on Halden Windows clients · **Review:** monthly, with expired rows removed · **Machine-readable twin:** `configs/baseline-exceptions-template.csv`

Status: EMPTY BY DESIGN — to be completed from the audit-mode run

This register is filled in **after** the 16 ASR rules have run in audit mode for at least seven days and their events (Event ID 1122) have been reviewed. An exception written before anything has been measured would be a guess, and the whole point of the audit period is to discover which legitimate business activity the rules would otherwise break.

No rule is currently listed as excluded, and ****no ASR exclusion may be added to a client until it has a row here**** with an owner and an expiry date.

1. How an exception gets here

Step	Who	Record
1. A rule in audit mode logs a business activity it would have blocked	IT	Event 1122 item in <code>evidence/raw/</code>
2. IT confirms the activity is legitimate and named (not "a user clicked something")	IT	Ticket
3. A decision is taken: narrow exclusion, keep the rule in audit, or change the business process	IT + department head	This register
4. Any exclusion is applied narrowly (a named path or a named process), never a whole drive	IT	Change record + this register
5. The exception is reviewed at the monthly check and removed when it expires	IT	This register

2. Register (awaiting the audit run)

Exception ID	Date raised	ASR rule (ID / name)	Scope	Reason	Risk accepted	Approved by	Expiry date	Status	Removal plan
<i>(none yet — complete after the audit-mode review)</i>									

3. Rules that keep running in audit mode (if any)

The one rule this project expects to make a deliberate decision about is:

Rule ID	Name	Expected decision	Reason
d1e49aac-8f56-4280-b9ba-993a6d77406c	Block process creations originating from PSEXec and WMI commands	Decide after the audit period	It is the rule most likely to conflict with management tooling. It is deployed in audit mode with the others and reviewed explicitly before any block.

If the decision is to keep it in audit, it is recorded here **and** passed to the blocking script with `- KeepAudit` , so the configuration and the register cannot drift apart.

4. Evidence to attach once the register is populated

Evidence	File (designed)
Audit events reviewed (7 days, per rule)	p04-ph2-asr-audit-events.csv (sanitized excerpt in evidence/public/)
The blocking state per client after the review	p04-ph2-asr-block-result.csv
The test trigger that proved a rule fires	p04-ph2-eicar-blocked.*
The exception rows applied to each client	the exclusion column of the block-result CSV

5. Rules for keeping this register honest

- **An exception needs an expiry date.** "Permanent" is not an expiry date.
- **An exception needs a named approver.** A department head for a business process; IT for a technical

decision, with the reason recorded.

- **An expired exception is removed**, and the rule returns to its standard mode.
- The compliance report counts audit-mode rules as a **failure** for control C4, so an exception that is not renewed becomes visible in the management figure rather than hiding inside it.
- A request to "just switch the rule off" is answered with the smallest exclusion that solves the actual problem, or by changing the process — not by weakening the rule for everyone.

Lab note: Halden Distribution Ltd. is a fictional company used for a home-lab portfolio project. This register is a real artefact of the change-control process; it is empty because nothing has been measured in the lab yet, and filling it with invented rows would be dishonest.